GDPR & DATA PROTECTION DASHBOARD

Full Compliance Insights & Legal Analysis Report

Period: January 2022 - December 2024 | 3 Years | 6 Compliance Domains

Author: Francisco Costa | Civil Law (Masters) | Data Analytics

1. Executive Summary

This report presents a comprehensive analysis of GDPR compliance performance across five regulatory domains spanning January 2022 through December 2024. The analysis is grounded in Regulation (EU) 2016/679 and draws on 1,480 records across six interrelated data tables processed through a SQLite database and visualised in Power BI using DirectQuery mode.

Total Breaches	DSAR Requests	Fine Exposure	Audit Findings	Processing Activities
400	600	EUR 1.89B	250	150

Overall Compliance Status

Domain	Key Metric	Result	Target	Status
Breach Notification (Art. 33)	72hr Compliance Rate	53.25%	90%	NON-COMPLIANT
Subject Rights (Art. 12)	30-Day Response Rate	66.36%	95%	NON-COMPLIANT
Fine Management (Art. 83)	Appeal Reduction Rate	9.49%	—	REVIEW
Audit Findings (Art. 24)	Remediation Rate	72.80%	80%	REVIEW NEEDED
Processing Activities (Art. 30)	Compliance Rate	74.00%	90%	NON-COMPLIANT
DPIA Completion (Art. 35)	% of Required Done	71.43%	100%	AT RISK

The analysis reveals persistent compliance gaps across all five domains. While fine appeals have reduced total exposure by EUR 179.73M, the organisation faces systemic challenges in breach notification speed, DSAR response times, and processing activity governance.

---

2. Legal Framework & Regulatory Background

The General Data Protection Regulation entered into force on 25 May 2018, establishing a harmonised data protection framework across the European Economic Area. As a Regulation it is directly applicable in all EU Member States, creating uniform obligations for all organisations processing personal data.

2.1 Key Articles Analysed

Article	Obligation	Fine Tier

Art. 5	Data Processing Principles	Tier 2: up to EUR 20M / 4% turnover
Art. 6	Lawful Basis of Processing	Tier 2: up to EUR 20M / 4% turnover
Art. 12	DSAR Response — 30 days	Tier 2: up to EUR 20M / 4% turnover
Art. 25	Privacy by Design and Default	Tier 1: up to EUR 10M / 2% turnover
Art. 30	Records of Processing Activities	Tier 1: up to EUR 10M / 2% turnover
Art. 32	Security of Processing	Tier 1: up to EUR 10M / 2% turnover
Art. 33	72-Hour Breach Notification	Tier 1: up to EUR 10M / 2% turnover
Art. 35	Data Protection Impact Assessment	Tier 1: up to EUR 10M / 2% turnover

2.2 Article 83 Fine Calculation Factors

- Nature, gravity and duration of the infringement
- Intentional or negligent character of the breach
- Actions taken to mitigate damage to data subjects
- Degree of responsibility — technical and organisational measures (Arts. 25 and 32)
- Previous infringements by the controller
- Degree of cooperation with the supervisory authority
- Categories of personal data affected

Critically, recurring audit findings can constitute an aggravating factor under Art. 83(2)(d), indicating a lack of appropriate organisational measures. A recurring rate of 28.80% in this dataset represents material risk in any regulatory investigation.

---

3. Data Breach Analysis — Article 33

3.1 Questions Answered

- What is the overall 72-hour notification compliance rate and how does it compare to the legal threshold?
- Which breach types generate the highest risk to data subjects?
- Which departments are the primary sources of breach incidents?
- Is compliance trending positively or negatively across 3 years?

Total Breaches	Notified On Time	Notified Late	72hr Rate	Avg Notif. Hours
400	213	187	53.25%	77.90

3.2 Compliance by Severity

Severity	Total	On Time	Late	Compliance Rate	Avg Notif. Hours
Critical	45	33	12	73.3%	52.2
High	78	71	7	91.0%	43.6
Medium	137	86	51	62.8%	62.8
Low	140	23	117	16.4%	120.0

3.3 Key Insights

- Overall 72-hour compliance rate of 53.25% is critically below the legal threshold — placing the organisation in clear violation of Art. 33 for nearly half of all breaches
- High severity breaches achieve the best compliance rate (91.0%) — suggesting escalation procedures work well for visible incidents but fail for routine ones
- Low severity breaches have the worst compliance rate at 16.4% — 117 of 140 low severity breaches were notified late, indicating systematic deprioritisation
- Average notification time of 77.90 hours exceeds the 72-hour limit — the average breach is already non-compliant before notification is made
- Accidental Disclosure (61 breaches) and Lost/Stolen Devices (57) are most frequent — both preventable through training and device encryption policies

3.4 Legal Analysis

The 72-hour obligation applies from the moment the controller becomes aware of the breach, not from when it occurred. EDPB Guidelines 9/2022 clarify that awareness exists when the controller has a reasonable degree of certainty that a security incident has occurred resulting in compromise of personal data.

The persistent failure to notify on time for Low severity breaches suggests a triage policy incorrectly applying a severity filter to a time-bound legal obligation. Art. 33(1) requires notification unless the breach is unlikely to result in risk to rights and freedoms — this risk assessment must happen within 72 hours, not after.

---

4. Subject Rights Requests — Article 12

4.1 Questions Answered

- What is the overall 30-day response compliance rate?
- Which request types are most frequent and hardest to process within deadline?
- Which departments are consistently missing the deadline?
- Are refusals legally justified under GDPR exemptions?

Total Requests	Completed	Pending	30-Day Rate	Avg Response
600	541	59	66.36%	23.27 days

4.2 Compliance by Request Type

Request Type	Volume	Share
Restriction of Processing	131	21.8%
Subject Access Request	101	16.8%
Objection to Processing	97	16.2%
Right to Erasure	95	15.8%
Data Portability	91	15.2%
Rectification	85	14.2%

4.3 Compliance by Department

Department	Compliance Rate	Status
Finance	75.0%	AT RISK
Operations	73.6%	AT RISK
Procurement	70.0%	NON-COMPLIANT
IT	69.0%	NON-COMPLIANT
Customer Service	68.9%	NON-COMPLIANT
Marketing	68.3%	NON-COMPLIANT

4.4 Key Insights

- 30-day compliance rate of 66.36% means 1 in 3 completed requests missed the legal deadline — a systemic failure
- Average response time of 23.27 days appears satisfactory but masks late outliers well beyond 30 days
- Restriction of Processing requests lead in volume (131) — data subjects are increasingly aware of Art. 18 rights
- No department achieves the 95% target — even the best performer (Finance at 75%) is 20 points below target

- Marketing at 68.3% is particularly concerning given heavy reliance on Consent as lawful basis — objection rights under Art. 21 must be actioned promptly

Article 12(5) permits refusal where requests are manifestly unfounded or excessive — the 9.83% refusal rate is a legitimate compliance tool. However, the burden of proof lies with the controller, and refusals must be documented with the right to lodge a supervisory authority complaint communicated to the data subject.

---

5. Fine Exposure & Regulatory Actions

Total Issued	Final Amount	Saved via Appeals	Appeal Rate
EUR 1,894.78M	EUR 1,715.05M	EUR 179.73M	41.25%

5.1 Fines by Supervisory Authority

Authority	Country	Total Fines
DPA (Ireland)	Ireland	EUR 537.90M
CNIL (France)	France	EUR 448.23M
ICO (UK)	UK	EUR 291.57M
Garante (Italy)	Italy	EUR 274.46M
BfDI (Germany)	Germany	EUR 220.88M
AEPD (Spain)	Spain	EUR 121.75M

5.2 Most Breached Articles

Article	Actions	Description
Art. 32 — Security	16	Security of Processing — most enforced
Art. 25 — by Design	15	Privacy by Design and Default
Art. 33 — Notification	10	Breach Notification — 72 hours
Art. 35 — DPIA	10	Data Protection Impact Assessment
Art. 5 — Principles	10	Core Data Processing Principles
Art. 6 — Lawfulness	9	Lawful Basis of Processing
Art. 17 — Erasure	7	Right to Erasure
Art. 13/14 — Transparency	3	Transparency Obligations

5.3 Key Insights

- Art. 32 Security failures most frequently enforced — directly linked to the high breach volume in Section 3
- DPA (Ireland) leads in total fines — reflecting Ireland's role as lead supervisory authority for major technology companies under the one-stop-shop mechanism (Art. 60)
- Appeals are worth pursuing — 39.39% of appeals resulted in reduced fines, delivering a collective saving of EUR 179.73M
- Art. 25 (Privacy by Design) appearing second confirms systems are being built without embedding privacy controls — a fundamental design failure

The Schrems II ruling (Data Protection Commissioner v Facebook Ireland, C-311/18, July 2020) invalidated the EU-US Privacy Shield, forcing reliance on Standard Contractual Clauses as the primary transfer mechanism. Controllers using SCCs must now conduct Transfer Impact Assessments to verify equivalent protection in destination countries.

---

6. Audit Findings & Risk Assessment

Total Findings	Outstanding	Remediation Rate	Recurring Rate
250	68	72.80%	28.80%

6.1 Most Common Finding Types

Finding Type	Count	Share	Risk Level
Process Failure	48	19.2%	HIGH
Technical Vulnerability	48	19.2%	CRITICAL
Access Control Issue	43	17.2%	CRITICAL
Policy Gap	42	16.8%	HIGH
Training Gap	40	16.0%	MEDIUM
Documentation Missing	29	11.6%	HIGH

6.2 Key Insights

- Remediation rate of 72.80% is below the 80% target — 68 findings remain outstanding including critical items
- Recurring rate of 28.80% is the most concerning metric — nearly 1 in 3 findings reappears, indicating root causes are not being addressed
- Technical Vulnerabilities and Access Control Issues combined account for 36.4% of all findings — directly linked to breach volume in Section 3

- Documentation Missing (29 findings) is a direct Art. 5(2) accountability failure — controllers must be able to demonstrate compliance
- Recurring findings constitute an aggravating factor under Art. 83(2)(d) in any regulatory investigation

---

7. Processing Activities Register — Article 30

Total Activities	Compliance Rate	DPIA Completion	Cross-Border	DPIA Outstanding
150	74.00%	71.43%	66	25

7.1 Lawful Basis Distribution

Lawful Basis	Activities	Share	Legal Note
Legal Obligation	28	18.7%	Art. 6(1)(c) — strong, well-defined basis
Contract	27	18.0%	Art. 6(1)(b) — must be necessary for contract
Vital Interests	27	18.0%	Art. 6(1)(d) — last resort, life/death situations only
Public Task	25	16.7%	Art. 6(1)(e) — requires basis in law
Legitimate Interests	23	15.3%	Art. 6(1)(f) — requires LIA, most misapplied
Consent	20	13.3%	Art. 6(1)(a) — must be freely given, specific, informed

7.2 Key Insights

- 74% compliance means 39 of 150 activities operate without full GDPR compliance — a significant liability under Art. 30
- Vital Interests applied to 27 activities is legally problematic — Art. 6(1)(d) is intended for genuine life-or-death situations, not routine processing
- 25 outstanding DPIAs represent the highest legal risk — processing cannot lawfully proceed for high-risk activities without a completed DPIA under Art. 35
- 66 cross-border transfers require Transfer Impact Assessments post-Schrems II — failure to conduct TIAs alongside SCCs is an Art. 46 violation

---

8. Future Steps & Compliance Roadmap

8.1 Immediate Priority — 0 to 3 Months

- Implement automated 72-hour breach notification tracking — eliminate manual triage delays for Low severity incidents

- Close all 25 outstanding DPIAs before affected processing activities continue
- Complete remediation of all Critical and High audit findings immediately
- Audit all 27 activities using Vital Interests — reassign to appropriate basis or discontinue processing

8.2 Short-Term — 3 to 6 Months

- Implement a DSAR case management system — automate deadline tracking and department-level escalation alerts
- Conduct Legitimate Interests Assessments for all 23 activities using Art. 6(1)(f)
- Deploy Transfer Impact Assessments for all 66 cross-border transfer activities
- Mandatory GDPR training for Customer Service, Marketing, IT and Sales — the four lowest DSAR compliance performers
- Root cause analysis for all 72 recurring audit findings — structural fixes not cosmetic remediation

8.3 Strategic Initiatives — 6 to 12 Months

- Embed Privacy by Design (Art. 25) into all new system development — privacy review gates at design, build and launch
- Implement this Power BI dashboard as a live operational compliance monitoring tool
- Establish a proactive fine appeals strategy — 39.39% reduction success rate confirms legal challenge delivers measurable value
- Review and consolidate the Art. 30 register — target 95% compliance through quarterly review cycles
- Consider strengthening the DPO function given the scale of compliance gaps identified

---

9. Conclusion

This analysis reveals an organisation at a critical juncture in its GDPR compliance journey. Three years of data show persistent gaps across all five compliance domains — not isolated failures, but systemic patterns requiring structural intervention.

The most urgent legal risk is breach notification compliance (53.25% — Art. 33). The most financially significant risk is the outstanding DPIA gap (25 activities — Art. 35). The most strategically valuable finding is that appeals work — EUR 179.73M has been recovered through the appeal process, confirming that legal challenge is a legitimate and effective compliance tool.

The intersection of Civil Law expertise and data analytics enables an analysis that goes beyond numbers — connecting regulatory obligations, enforcement patterns, and

operational data into actionable compliance intelligence. That combination is the core value proposition of this dashboard.

— End of Report —